

Soroush Maleki

Offensive Security Researcher · Web Application Penetration Testing

voidseraphimsora@gmail.com · sourallism@gmail.com · +98 990 776 9514 · github.com/abysseraphim

PROFESSIONAL SUMMARY

Self-taught offensive security researcher specializing in web application penetration testing and security tool development. My approach is manual-first and logic-driven — I focus on understanding how applications behave at the architectural level rather than relying on automated scanners. I build custom tooling to support depth of analysis and apply structured thinking honed through a clinical background in nursing to vulnerability research and risk assessment. Authored two technical books on offensive web security (CipherStack series, published on Zenodo). Built and open-sourced eight security tools spanning static analysis, reconnaissance, fuzzing, and HTTP testing across Python, Go, and Bash.

SECURITY TOOLS & PROJECTS

All tools available at: github.com/abysseraphim

TaintHound [Python] github.com/abysseraphim/TaintHound

AST-based static taint-flow analysis tool for client-side JavaScript. Traces data from user-controllable sources to dangerous sinks to surface DOM XSS, open redirects, and unsafe eval/Function usage.

- ▶ tree-sitter JS AST (not regex) — understands assignments, function calls, and return-value propagation; detects 15+ sources and 20+ dangerous sinks
- ▶ Two collection modes: local directory scan or headless Chromium crawl; outputs structured JSON reports and dependency-free SVG flow diagrams

Lurak [Bash] github.com/abysseraphim/Lurak

Modular Linux-first reconnaissance framework for attack surface enumeration. Orchestrates 14 independent recon modules with a TUI, structured JSON output, and a Smart Pipeline for full-chain automation.

- ▶ 14 modules: ASN recon, CIDR discovery, port scanning, subdomain enumeration (7 passive sources), DNS bruteforce, HTTP fingerprinting, CDN detection, SSL inspection
- ▶ All output in structured JSON + flat unique lists; Smart Pipeline auto-chains modules for unattended domain/IP/CIDR engagements

AuthFlowVisualizer (AFV) [Go + Node.js] github.com/abysseraphim/AuthFlowVisualizer

Static analysis tool that parses JavaScript applications using the Babel AST to extract authentication-related behavior, build call graphs, and generate both CLI and HTML flow reports.

- ▶ Full pipeline: Babel parser → AST normalization → function/endpoint/call extraction → Program Call Graph + Auth Flow Graph
- ▶ Written in Go with Node.js Babel bridge; detects 20+ authentication keywords across local source or remote URL crawl

Freecollapse [Python] github.com/abysseraphim/Freecollapse

Fuzzing tool inspired by reCollapse for generating boundary-case payloads targeting normalization vulnerabilities, path traversal, and encoding edge cases in web applications.

- ▶ Generates mutation-based payload sets targeting normalization-class bugs: path collapsing, Unicode handling, double-encoding, null-byte injection

HttpRequestLab (BurpLite) [Python / PySide6] github.com/abysseraphim/HttpRequestLab

Lightweight desktop HTTP requester for manual security testing. Designed as a standalone alternative to Burp Repeater for quick request crafting and inspection.

- ▶ Raw HTTP request editing with auto Host sync, follow-redirects toggle, full response viewer; PySide6 GUI optimized for rapid manual testing iteration

HT-Detective [Python] github.com/abysseraphim/HT-Detective

Web application fingerprinting and technology detection tool for attack surface profiling.

- ▶ Detects server technologies, frameworks, CMS platforms, and security headers; designed for pre-engagement recon pipelines

Paramancer [Python] github.com/abysseraphim/Paramancer

Parameter discovery and manipulation tool for web application security testing.

- ▶ Enumerates hidden and undocumented parameters via fuzzing-based discovery and passive response extraction

PUBLICATIONS

CipherStack-Offense · 343 pages · Zenodo (DOI available)

Comprehensive offensive web application security reference covering vulnerability classes, attack chains, and exploitation techniques. Structured for practitioners with detailed technical depth on authentication bypass, injection techniques, client-side attacks, and chained multi-step exploitation scenarios.

CipherStack-Dev · 520 pages · Zenodo (DOI available)

Security-oriented development reference covering Python, JavaScript, Go, Bash, and PHP from an offensive security perspective. Focuses on understanding language internals and common implementation patterns that introduce vulnerabilities.

TECHNICAL SKILLS

Web Security: Manual application logic analysis, authentication & authorization abuse, session handling flaws, IDOR, privilege escalation, business logic vulnerabilities, DOM-based XSS, open redirect, SQLi, NoSQL injection, CSRF, API security testing, information disclosure chains

Reconnaissance: Subdomain enumeration, ASN & CIDR mapping, DNS intelligence, passive/active infrastructure profiling, CDN detection, SSL/TLS inspection, attack surface analysis at scale

Static Analysis: AST-based JavaScript analysis (tree-sitter, Babel), taint flow tracing, source-to-sink path resolution, authentication flow extraction

Languages: Python, Bash, Go, JavaScript · HTML/CSS · C (foundational)

Tools: Burp Suite, Nmap, subfinder, naabu, dnsx, shuffledns, ffuf, Playwright, Wireshark

Platforms: Linux (Arch, Debian/Ubuntu) · CLI-first workflows · Git

RESEARCH & PRACTICE

- ▶ 20+ PortSwigger Web Security Academy labs completed with full professional writeups — each documented as a structured vulnerability report with reproduction steps, impact analysis, and remediation (github.com/abysseraphim)
- ▶ CTF competitions — focus areas: web exploitation, Linux, network analysis
- ▶ Continuous self-directed research in web application security and offensive tooling
- ▶ Bug bounty programs: familiarization phase — active learning and reconnaissance on public programs; first confirmed finding not yet submitted

EDUCATION

Bachelor of Science in Nursing · Semnan Azad University · 2025

Clinical background developed precision, structured thinking, and systematic analysis skills under pressure — directly transferable to vulnerability assessment, risk evaluation, and security documentation.

Fluent in Persian (native) · English (technical & professional proficiency)